# 📌 【小南题解】AP 令和4年春期 午後問1（网络安全／情報セキュリティ）

> **主题**：电商网站网页篡改事件与零日漏洞应急响应（WAF调优误报、SIEM日志相关分析、CSIRT应急指挥、系统加固）
>
> **考点标签**：`ゼロデイ攻撃` `WAF（Web Application Firewall）` `過検知（False Positive）` `SIEM` `インシデント対応チーム` `不要なサービスの停止`
>
> **难度系数**：⭐⭐⭐☆☆（AP 午后安全方向高频必考真题，技术概念与应急响应 SOP 全覆盖）

## 💡 小南一句话导读

本题以 R 公司电商网站遭受 CMS 漏洞攻击导致网页被篡卡为背景，极具现实代表性地展示了"纵深防御体系构建（Defense in Depth） ──► 零日漏洞爆发与紧急闭站止损 ──► WAF 误报（過検知）调优瓶颈 ──► SIEM 自动化日志相关分析与 CSIRT 应急指挥"的全过程。

概念密度极高、逻辑丝丝入扣，是掌握网络安全防御与事故响应（Incident Response）的绝对黄金范例！

## 🏢 1. 背景与网络架构梳理

- **受害对象**：R 公司电商网站（采用 CMS 搭建，涉及会员个人信息与在线交易）。
- **现有防御架构（表1）**：
  - **网络层**：IPS（基于特征码/Signature 的不正侵入防御）、FW/路由器（端口封禁与无关通信遮断）。
  - **服务器层**：日志服务器集中收集 Log；清理无用账号与**停止不必要的服务（不要なサービスの停止）**。
  - **应用层/数据层**：OS/中间件/CMS 每日核查修复补丁；部署软件型 **WAF** 防御 Web 应用攻击。
- **事故爆发与暴露出的短板（表2）**：
  - **事故本质**：黑客利用 CMS 尚未发布补丁的零日漏洞（Zero-day）篡改网页，将会员诱导至钓鱼网站。

- **管理与技术痛点：**
  1. WAF 规则更新后由于过检测（過検知／False Positive）误拦截了正常业务通信，运维不敢更新特征码。
  2. 缺乏明确的紧急闭站授权决策机制，导致切断受害网站耗时过长。
  3. 海量日志全靠人工离散检索，相关分析（Correlation Analysis）效率极低，延迟了公开发布与恢复。

# 🧩 2. 逐题解构与破题要领

## 🔷 設問 1：服务器安全基线与服务停止 [a]

- **题目破题：**
  填入表 1 项番 4 中 CMS 服务器与 DB 服务器为缩小攻击面（Attack Surface）而采取的强化措施 `a`（5字以内）。
- **逻辑推导：**
  服务器出厂默认开启了许多不必要的后台进程与通信端口。安全加固（Hardening）的标准做法是“删除不必要账号（不要なアカウントの削除）”以及“停止不必要的服务（不要なサービスの停止）”。
- ✅ **标准答案：** `サービス`

## 🔷 設問 2：Web 应用防护神器 [b]

- **题目破题：**
  填写表 1、表 2 及正文中用于防护 Web 应用攻击（如 SQL 注入、XSS 等）、基于特征码检查 HTTP/HTTPS Payload 的设备/软件 `b`（英文字母 3 字）。
- **逻辑推导：**
  运行在 Web 服务器前端或服务器内部，能够深度解析 HTTP 报文内容、根据规则库过滤恶意 Web 攻击的专门安全组件就是 **WAF**（Web Application Firewall）。
- ✅ **标准答案：** `WAF`

## 🔷 設問 3：漏洞资产管理要素（多选题）

- **题目破题：**
  下划线①中，为了核查 OS、中间件与 CMS 是否存在漏洞及对应补丁，必须对企业内部软件资产管理哪些关键信息？（在选项中选择全部正确项）
- **选项分析：**

- **ア 販売価格 / エ ライセンス**：属于财务与合规授权范畴，与技术漏洞防护无直接关系。
- **イ バージョン（版本）**：漏洞（CVE）通常精准对应特定的版本区间（如 v2.4.1~v2.4.5），版本号是匹配漏洞的第一要素。
- **ウ 名称（名称）**：必须精准记录软件的官方名称（如 Apache, WordPress），才能正确检索对应的官方安全公告。

- ✅ **标准答案**：`イ、ウ`

## 🔷 設問 4：事件响应、WAF 调优与日志相关分析

### (1) 漏洞攻击类型推导

- **题目破题**：
  下划线②指出“攻击爆发时，厂商**尚未发布**对应的修复补丁”，求这种攻击的专业术语（8字以内）。
- **逻辑推导**：
  利用软件已被发现但官方尚未发布修复补丁（Patch）的时间窗口（Day 0）发起的攻击，被称为**零日攻击（ゼロデイ攻撃／Zero-day Attack）**。
- ✅ **标准答案**：`ゼロデイ攻撃`（或 `ゼロデイアタック`）

### (2) 零日攻击的临时对策依据

- **题目破题**：
  下划线③中，在补丁发布前要实施“临时对策（暂定对策，如关闭易受攻击的功能模块、配置 WAF 拦截规则）”，首先需要确认什么？（单选）
- **逻辑推导**：
  在无法打补丁的情况下，能否实施临时对策的前提是**调查并掌握该漏洞的具体回避方案/绕过对策（脆弱性の回避策を調査）**。
- ✅ **标准答案**：`ウ` (脆弱性の回避策を調査)

### (3) WAF 规则过严格引发的误报 [c]

- **题目破题**：
  表 2 项番 2 提到 WAF 规则升级后默认安全级别过高，导致“将正常通信误判断为攻击并拦截”，这种现象被称为 [c]。
- **逻辑推导**：

    - **过检测/误报（過検知／False Positive）**：把正常通信/合法用户请求误判为攻击并误杀拦截。
    - **未检测/漏报（未検知／False Negative）**：把真实恶意攻击误判为正常通信放行。
    - 文中描述"正常な通信まで遮断してしまう"，属于典型的**过检测（過検知）**。
- ✅ **标准答案**：`ア` (過検知)

**(4) 应急指挥主体 [d]**

- **题目破题**：
  填写制定应急响应规则并有权下达"关闭网站"止损指令的组织名称 [d]（15字以内，使用文中词句）。
- **逻辑推导**：
  正文中明确写道："设置专门处理安全事故、收集信息并向各担当下达响应指令的**インシデント対応チーム**（事故响应团队/CSIRT）"。因此下达闭站指令的主体即为此团队。
- ✅ **标准答案**：`インシデント対応チーム`

**(5) 自动化日志相关分析系统**

- **题目破题**：
  下划线④提到"收集各网络设备、服务器与软件的日志并进行时序**相关分析（相関分析）**，自动检测事故前兆与痕迹并通知管理员"的系统简称（字母 4 字）。
- **逻辑推导**：
  能够跨设备（FW、IPS、Server、WAF）集中收集 Syslog/EventLog，利用规则引擎与时序算法进行关联分析并实时告警的安全管理平台，就是 **SIEM**（Security Information and Event Management）。
- ✅ **标准答案**：`SIEM`

## 📝 3. 考点总结卡片

```
### 🎯 AP 午后 Security 核心考点总结

1. WAF 调优与误报机制 (False Positive vs False Negative):
   - 過検知 (False Positive / 誤検知): 规则过严，误拦截合法用户请求（正常通信）。
```

- 未検知（False Negative / 漏検知）：规则过松，放行恶意攻击报文。
- 解决方案：引入托管型/云型 WAF，由专业安全团队动态调优（チューニング）。

2. ゼロデイ攻撃（Zero-day Attack）应急响应 SOP：
- 阶段 1：尚未有 Patch 时 ⟶ 调查回避策（回避策の調査）并部署“暂定对策（暫定対策）”。
- 阶段 2：官方 Patch 发布后 ⟶ 测试环境验证 ⟶ 生产环境展开。

3. SIEM（Security Information and Event Management）：
- 核心能力：日志集中收集 + 时序相关分析（相関分析）+ 自动化威胁告警。
- 解决痛点：改变以往事故后人工盲目翻找离散日志的被动局面。

4. 事故响应组织（CSIRT）：
- インシデント対応チーム（CSIRT）：具备跨部门调配资源与决定系统停机/闭站止损的最高授权。